

KUBERNETES AI SECURITY MONITOR

Final Year Project – ATU Galway
Alex Paton: G00424185





- Kubernetes is a **container orchestrator**.
- It automates **deploying, scaling, and managing** of containerised applications.

- Kubernetes doesn't run raw code, it runs **containers**, and containers come from **images**.
- Dockerfile → built image → pushed image to registry → Kubernetes Deployment.

- Many large companies use Kubernetes (**Spotify, Airbnb, Snapchat, Ericsson**)
- Easier **Scaling, Rolling updates & quick rollbacks, Supports microservices**

AWS EC2 Server

Kubernetes Cluster

Node.js Backend

kubectl port-forward svc/prometheus 9090:9090

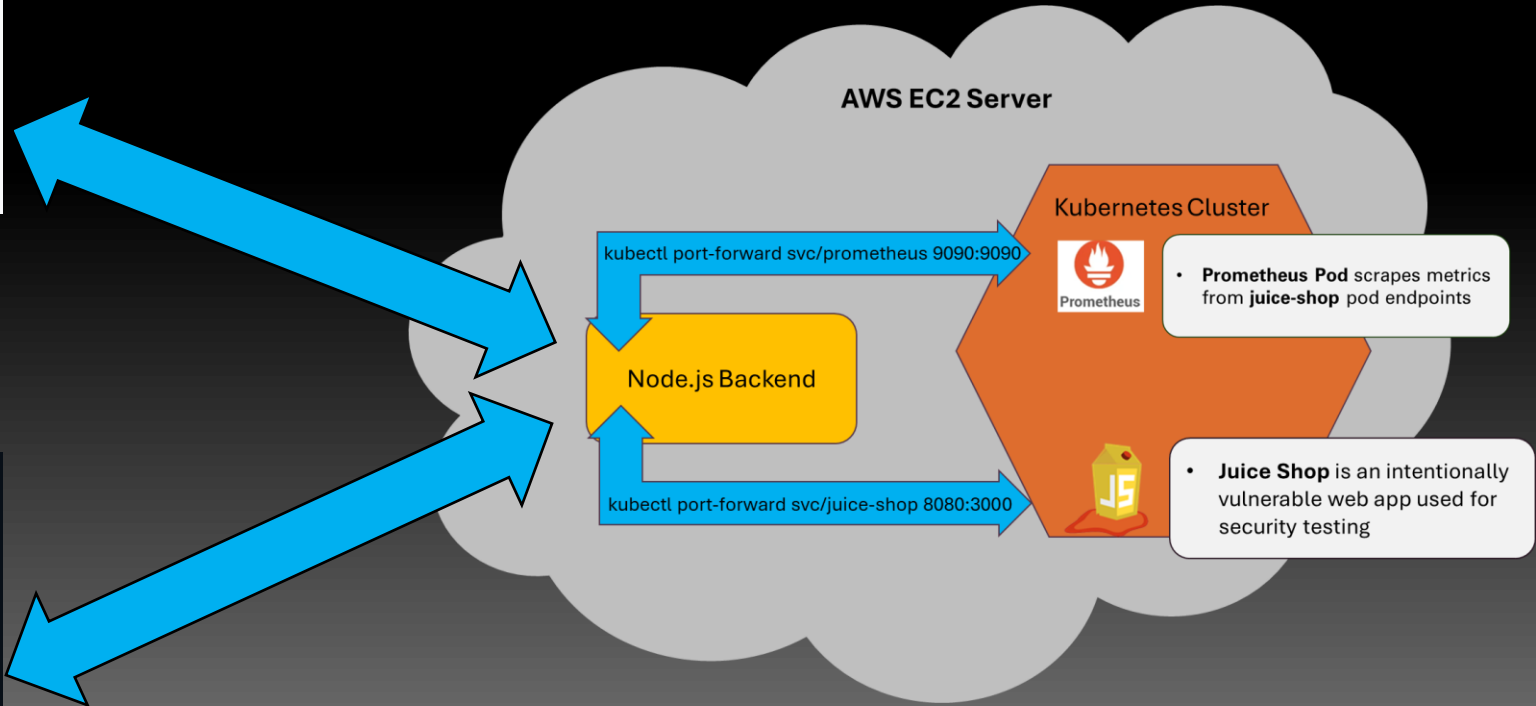
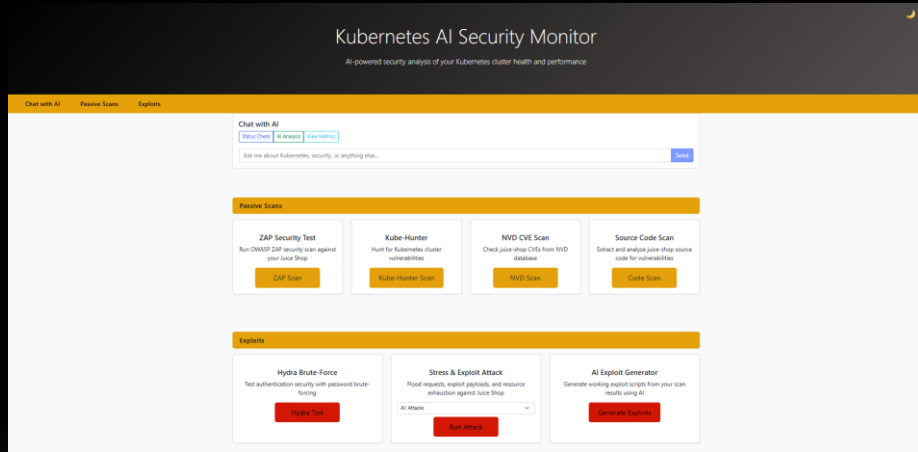


- **Prometheus Pod** scrapes metrics from **juice-shop** pod endpoints

kubectl port-forward svc/juice-shop 8080:3000



- **Juice Shop** is an intentionally vulnerable web app used for security testing



Source Code Scan

Exploits for Confirmed Vulnerabilities in OWASP Juice Shop

Below are the detailed exploits for the confirmed vulnerabilities identified in the OWASP Juice Shop instance based on the provided scan results. Each exploit includes the vulnerability name, a working exploit script or command, an explanation of the exploit, and a severity rating.

1. SQL Injection in `routes/login.ts`

Vulnerability

SQL Injection

Scan Reference: Code snippet in `routes/login.ts`

The `email` and `password` fields are directly interpolated into an SQL query, making it vulnerable to SQL injection.

Exploit

```
curl -X POST http://<JUICE_SHOP_IP>:<PORT>/rest/user/login \  
-H "Content-Type: application/json" \  
-d '{"email": "admin@juice-sh.op\' OR \'1\'=\'1", "password": "anything"}'
```

Explanation

The SQL injection payload `admin@juice-sh.op' OR '1'='1` bypasses the authentication check by always evaluating the SQL condition as true. This allows an attacker to log in as the admin user without knowing the actual password.

Impact

The attacker gains unauthorized access to the admin account, which can lead to full control of the application.

Severity

Critical

Exploit Generator

Chat with AI

[Status Check](#) [AI Analysis](#) [View Metrics](#)

Ask me about Kubernetes, security, or anything else...

Send

AI Chat (2 messages)

You: How is my cluster today ?

AI:
Your cluster looks stable. The Juice Shop pod is running, with one container ready and no current errors or crashes. The pod has restarted three times, but the last restart was almost three days ago, so it's likely not an immediate issue. Logs show the app is functioning correctly, detecting required files and dependencies.

While the application is running smoothly, the latest source code scan highlights vulnerabilities within its design, which are intentional since Juice Shop is built for security training. These vulnerabilities do not affect the cluster but serve as teaching opportunities.

Let me know if you'd like a deeper dive into any specific area!

Juice Shop Pod Metrics

Pod Status
RUNNING

Restarts
3

CPU Usage (%)



juice-shop-585f644f4-fqqzq

Memory Usage (MiB)



juice-shop-585f644f4-fqqzq

- Chat box with scan context
- Live Pod metrics

Vulnerability Analysis for Juice-Shop Pod

Overview

This analysis identifies high-severity vulnerabilities affecting the Juice-Shop application based on the provided CVEs. The Juice-Shop application uses Node.js, Express, Angular, and SQLite as dependencies. The focus is on high-severity vulnerabilities (CVSS ≥ 7), specific risks associated with each, and actionable remediation steps.

High-Severity Vulnerabilities

1. CVE-2016-10524

- **Description:** The `i18n-node-angular` module exposes a REST API endpoint used for development purposes, which allows remote attackers to execute arbitrary code via crafted input.
- **CVSS Score:** 8.2 (High)
- **Risk:** Remote code execution (RCE) vulnerability. Attackers can exploit this to execute arbitrary commands on the server, potentially leading to full system compromise.
- **Affected Component:** `i18n-node-angular` module.
- **Remediation:**
 - Upgrade the `i18n-node-angular` module to a patched version (if available).
 - If the module is not actively maintained, consider replacing it with a more secure alternative.
 - Restrict access to the development REST API endpoint using network-level controls (e.g., firewall rules).
 - Conduct a code review to ensure no sensitive endpoints are exposed in production.

2. CVE-2006-4102

- **Description:** PHP remote file inclusion vulnerability in `tpl.inc.php` in SQLiteWebAdmin 0.1 and earlier allows remote attackers to execute arbitrary PHP code via crafted input.
- **CVSS Score:** 7.5 (High)
- **Risk:** Remote file inclusion (RFI) vulnerability. Attackers can execute arbitrary PHP code, potentially leading to data theft, system compromise, or further exploitation.
- **Affected Component:** SQLiteWebAdmin.
- **Remediation:**
 - If SQLiteWebAdmin is used, update to a secure version or remove it entirely if not required.
 - Validate and sanitize all user inputs to prevent file inclusion attacks.
 - Use web application firewalls (WAFs) to detect and block malicious payloads targeting this vulnerability.

- The **National Vulnerability Database** (NVD) API is completely free and public, maintained by **National Institute of Standards and Technology** (NIST), and contains every officially registered **Common Vulnerability and Exposure** (CVE) going back decades.
- This scans for CVE'S related to each technology in Juice Shop's stack.

Thank You !